SIMATS ENGINEERING
CSA6303- Threat Intelligence and Network Security
CO2-AT1-Threat Intelligence Report

Assessment Questions

Subject	Threat Intelligence	**Total Marks**	50
Questions	10 (all compulsory)	**Marks per Question**	5
Reg.No	192311098	**Name**	B.Hari Sai
Faculty	Dr.V.Parthipan	**Slot**	A

Instructions: Answer all questions. Each question carries 5 marks. Support answers with examples and diagrams where appropriate.

Code of Conduct:

I **B.Hari Sai/192311098** (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of Student :B.Hari Sai

Questions

Q1. Malware [5 Marks]

Define malware and explain any four types of malware (virus, worm, trojan, ransomware, spyware). For each type, state how it spreads and one impact on the victim.

Q2. Phishing [5 Marks]

Describe how a phishing attack is carried out. Differentiate between spear phishing, whaling and vishing, and list three measures an organisation can adopt to reduce phishing risk.

Q3. DoS and DDoS [5 Marks]

Distinguish between a Denial of Service (DoS) attack and a Distributed Denial of Service (DDoS) attack. Explain the working of a SYN flood and outline two mitigation techniques.

Q4. Man-in-the-Middle Attacks [5 Marks]

What is a Man-in-the-Middle (MITM) attack? Explain two techniques used to carry it out (for example ARP poisoning, rogue Wi-Fi access point, SSL stripping) and state how encryption helps defend against it.

Q5. Spoofing and Sniffing [5 Marks]

Compare spoofing and sniffing. Explain IP spoofing and ARP spoofing with an example each, and describe how packet sniffers such as Wireshark can be used both maliciously and legitimately.

Q6. Vulnerability Assessment [5 Marks]

Explain the vulnerability assessment process. Describe its main phases, and differentiate between vulnerability assessment and penetration testing. Name two commonly used scanning tools.

Q7. Vulnerability Scoring [5 Marks]

What are CVE and CVSS? Explain how CVSS scores help in prioritising vulnerabilities and why a high CVSS score alone may not decide the order of patching.

Q8. Threat Data Sources and OSINT [5 Marks]

Discuss the main sources of threat data (internal, external, open-source and commercial). Define Open-Source Intelligence (OSINT) and describe three OSINT sources or tools used in threat intelligence gathering.

Q9. Indicators of Compromise (IoCs) [5 Marks]

What are Indicators of Compromise (IoCs)? Classify them into network-based, host-based and file-based indicators with two examples of each, and explain how a security team uses IoCs during incident response.

Q10. Threat Feeds [5 Marks]

Explain what a threat intelligence feed is. Describe the common feed formats and sharing standards (STIX/TAXII), list two advantages and two limitations of using threat feeds, and name two example feeds.

Marking Scheme (for evaluator)

Q.No	Expected points and mark distribution (total 5)
1	Definition (1); four types with spread method and impact (4 x 1 = 4).
2	Attack flow (1.5); three variants differentiated (1.5); three countermeasures (2).
3	DoS vs DDoS (1.5); SYN flood working (1.5); two mitigations such as rate limiting, SYN cookies, CDN/scrubbing, blackhole routing (2).
4	Definition and interception concept (1); two techniques (2); defences such as TLS, HSTS, certificate validation, VPN (2).
5	Comparison (1); IP and ARP spoofing with examples (2); sniffer dual use (1.5); one countermeasure (0.5).
6	Phases: asset discovery, scanning, analysis and prioritisation, reporting, remediation (2); VA vs pen test (2); two tools such as Nessus, OpenVAS, Qualys (1).
7	CVE meaning (1); CVSS meaning and severity ratings (1.5); role in prioritisation (1.5); context factors such as exploitability and asset criticality (1).
8	Threat data source categories (2); OSINT definition (1); three OSINT sources or

Q.No	Expected points and mark distribution (total 5)
	tools such as Shodan, VirusTotal, WHOIS, social media, dark web monitoring (2).
9	Definition (1); classification with examples (3); use in detection and response (1).
10	Definition (1); STIX/TAXII or similar formats (1.5); two advantages and two limitations (2); two example feeds such as AlienVault OTX, MISP, abuse.ch (0.5).

Answers:

Q1. Malware (5 Marks)

Definition

Malware is malicious software designed to damage systems, steal information, or gain unauthorised access.

Four types of malware

- Virus: Attaches to files and spreads when infected files are executed. Impact: Corrupts or deletes files.
- Worm: Replicates and spreads automatically through networks. Impact: Consumes bandwidth and slows systems.
- Trojan Horse: Disguises itself as legitimate software and spreads when installed by users. Impact: Provides attackers unauthorised access.
- Ransomware: Commonly spreads through malicious email attachments or compromised websites. Impact: Encrypts files and demands ransom.

Q2. Phishing (5 Marks)

Definition

Phishing is a cyberattack in which attackers impersonate trusted organisations or people to steal sensitive information.

How it works

- The attacker sends a fake email, message, or link.
- The victim clicks the link and visits a fraudulent website.
- The victim enters credentials or downloads malware.
- The attacker steals information or gains access.

Types

- Spear phishing: Targets a specific individual or organisation.
- Whaling: Targets senior executives or high-level officials.
- Vishing: Uses phone calls or voice messages to deceive victims.

Three preventive measures

- Conduct regular security awareness training.
- Use multi-factor authentication (MFA).
- Apply email filtering and verify suspicious links.

Q3. DoS and DDoS (5 Marks)

Definitions

- DoS (Denial of Service): Makes a service unavailable, usually using one main source.
- DDoS (Distributed Denial of Service): Floods a service using multiple compromised devices.

Differences

- DoS usually comes from one source; DDoS comes from multiple sources.
- DoS is generally easier to trace and block; DDoS is harder to trace and block.
- DDoS attacks often have a larger scale than DoS attacks.

Working of a SYN flood

- The attacker sends many TCP SYN requests.
- The server allocates resources and sends SYN-ACK responses.
- The attacker does not complete the TCP handshake.
- The server's connection queue fills, preventing legitimate connections.

Mitigation

- Enable SYN cookies and connection rate limiting.
- Use DDoS protection services, CDNs, or traffic scrubbing.

Q4. Man-in-the-Middle (MITM) Attacks (5 Marks)

Definition

A MITM attack occurs when an attacker secretly intercepts or alters communication between two parties.

Two techniques

- ARP Poisoning: The attacker sends false ARP messages on a local network to associate their MAC address with another device's IP address, allowing traffic interception.
- Rogue Wi-Fi Access Point: The attacker creates a fake Wi-Fi hotspot to intercept users' network traffic.

Defences and role of encryption

- Use HTTPS with valid TLS certificates.
- Enable HSTS to prevent insecure HTTP connections.
- Use trusted VPNs on untrusted networks.

- Encryption protects data from being read or modified in transit, provided certificates are properly validated and secure protocols are used.

Q5. Spoofing and Sniffing (5 Marks)

Comparison

Spoofing means falsifying an identity or address. Sniffing means capturing and analysing network packets.

Examples

- IP Spoofing: An attacker forges the source IP address of packets. Example: Sending packets with a forged source IP to hide the actual source.
- ARP Spoofing: An attacker sends false ARP messages to associate their MAC address with a legitimate device's IP. Example: Redirecting local network traffic through the attacker's machine.

Packet sniffers such as Wireshark

- Malicious use: Capture unencrypted credentials or sensitive network traffic.
- Legitimate use: Troubleshoot network issues, inspect protocols, and investigate security incidents.

Countermeasure

Use encryption such as HTTPS/TLS and secure network configurations.

Q6. Vulnerability Assessment (5 Marks)

Definition

Vulnerability assessment is the systematic process of identifying, analysing, and prioritising security weaknesses in systems and networks.

Main phases

- Asset discovery: Identify systems, devices, and applications.
- Scanning: Detect known vulnerabilities using scanning tools.
- Analysis and prioritisation: Validate findings and assess severity and risk.
- Reporting: Document vulnerabilities and recommend fixes.
- Remediation and verification: Patch weaknesses and rescan to confirm fixes.

Vulnerability assessment vs penetration testing

- Vulnerability assessment identifies and prioritises weaknesses; penetration testing safely tests whether weaknesses can be exploited.
- Vulnerability assessment often uses automated scanners; penetration testing combines controlled manual and automated testing.
- Vulnerability assessment focuses on broad coverage; penetration testing focuses on demonstrating practical risk.

Tools

Nessus and OpenVAS (Greenbone).

Q7. Vulnerability Scoring (5 Marks)

Definitions

- CVE (Common Vulnerabilities and Exposures): A standard system for assigning identifiers to publicly known cybersecurity vulnerabilities.
- CVSS (Common Vulnerability Scoring System): A framework for rating vulnerability severity using scores from 0.0 to 10.0.

CVSS severity ratings

- 0.0: None
- 0.1–3.9: Low
- 4.0–6.9: Medium
- 7.0–8.9: High
- 9.0–10.0: Critical

Importance of CVSS

- Helps compare vulnerabilities and prioritise remediation.
- Highlights weaknesses with potentially serious consequences.
- Supports consistent risk communication.

Why CVSS alone is insufficient

Patch priority also depends on active exploitation, asset criticality, exposure to the internet, business impact, and availability of fixes. A lower-scored vulnerability actively exploited on a critical server may need immediate attention.

Q8. Threat Data Sources and OSINT (5 Marks)

Threat data sources

- Internal: System logs, firewall alerts, endpoint detection data, and incident reports.
- External: Information from security organisations and industry partners.
- Open-source: Publicly available security reports, advisories, and community feeds.
- Commercial: Paid threat intelligence platforms providing enriched threat information.

OSINT definition

OSINT (Open-Source Intelligence) is the process of collecting and analysing publicly available information to generate useful intelligence.

Three OSINT tools or sources

- Shodan: Finds internet-connected devices and exposed services.
- VirusTotal: Analyses files, URLs, and domains using multiple security engines.
- WHOIS: Provides domain registration information that can help investigate suspicious domains.

Importance

These sources help identify threats, investigate suspicious infrastructure, and assess organisational exposure.

Q9. Indicators of Compromise (IoCs) (5 Marks)

Definition

Indicators of Compromise are observable signs that a system or network may have been compromised.

Types and examples

- Network-based: Suspicious IP address; malicious domain.
- Host-based: Unusual process; unauthorised registry modification.
- File-based: Malware file hash; suspicious executable.

Use during incident response

- Detect suspicious activity in security monitoring systems.
- Search endpoints and logs for matching indicators.
- Block malicious IPs and domains where appropriate.
- Isolate infected devices and investigate the incident.
- Verify that the threat has been removed.

Note
IoCs should be evaluated in context because some indicators can be outdated or produce false positives.

Q10. Threat Feeds (5 Marks)

Definition
A threat intelligence feed is a regularly updated source of information about cyber threats, including malicious IP addresses, domains, file hashes, and attack techniques.

Formats and sharing standards
- CSV/JSON: Store and exchange structured threat indicators.
- STIX: Standardises the representation of threat intelligence.
- TAXII: Enables automated sharing and exchange of threat intelligence.

Advantages
- Enables faster detection of known threats.
- Supports automated security monitoring and response.

Limitations
- Feeds may contain outdated or false-positive indicators.
- Integration, maintenance, and large data volumes can require significant resources.

Example feeds
AlienVault Open Threat Exchange (OTX) and abuse.ch threat intelligence feeds.